

Vulnerability Remediation and Security Review Report

Internship: Sumerix Global Cybersecurity & Ethical Hacking Internship

Task 4: Vulnerability Remediation & Security Review

Submitted By: Aditya Narke

Domain: Cybersecurity & Ethical Hacking

Internship Program: Sumerix Global Virtual Internship

Department: Computer Science Engineering

Date: June 2026

Table of Contents

Sr No	Section Name	Page Number
1	Executive Summary	3
2	Introduction	3
3	Assessment Objectives	4
4	Scope of Assessment	4
5	Assessment Methodology	5-8
6	Remediation Findings and Recommendations	8-9
7	Risk Summary	10
9	Conclusion	10

1. Executive Summary

This report details the vulnerability remediation and security review process conducted following the initial assessment of the OWASP Juice Shop application in Task 3. The primary focus of this phase was to analyze the previously identified security gaps, plan necessary remediation strategies, and align the application configuration with OWASP security best practices.

The security analysis process involved a deep dive into the findings from Nmap, Nikto, and Dirsearch scans, prioritizing them based on risk severity. Remediation planning centered on implementing critical security headers, addressing permissive configuration settings, and managing information disclosure risks. This report documents these activities, providing a roadmap for hardening the application's security posture and fostering a more resilient defensive architecture.

2. Introduction

Vulnerability remediation is a critical phase in the software development lifecycle, transforming identified weaknesses into actionable security improvements. Effective remediation requires not only applying patches but also adopting a defense-in-depth approach, which includes secure configuration practices and compliance with recognized industry standards such as the OWASP Top 10.

This task emphasizes the transition from vulnerability identification to proactive security management. By studying and applying OWASP best practices—such as the implementation of strict HTTP security headers and secure server configurations—this review process aims to minimize the attack surface and mitigate risks such as Cross-Site Scripting (XSS), cross-origin attacks, and unauthorized information disclosure.

3. Assessment Objectives

The objectives of this security review were:

- Review and validate previously identified vulnerabilities from Task 3.
- Analyze security weaknesses discovered during initial assessment activities.
- Formulate comprehensive remediation methodologies for identified findings.
- Study and implement OWASP secure configuration practices.
- Improve the overall application security posture through hardening techniques.
- Develop practical, professional-grade security recommendations.
- Document all remediation activities in accordance with professional reporting standards.

4. Scope of Assessment

In Scope

- Review of previous Nmap findings (Network/Service perspective).
- Review of Nikto findings (Web/Security Header perspective).
- Review of Dirsearch findings (Path/Endpoint perspective).
- Implementation of security headers.
- Web application configuration hardening.
- Remediation planning and documentation.
- Application of OWASP security best practices.

Out of Scope

- Active exploitation of vulnerabilities.
- Denial of Service (DoS) testing.
- Testing on real-world production environments.
- Interaction with unauthorized systems or networks.
- Advanced active penetration testing.

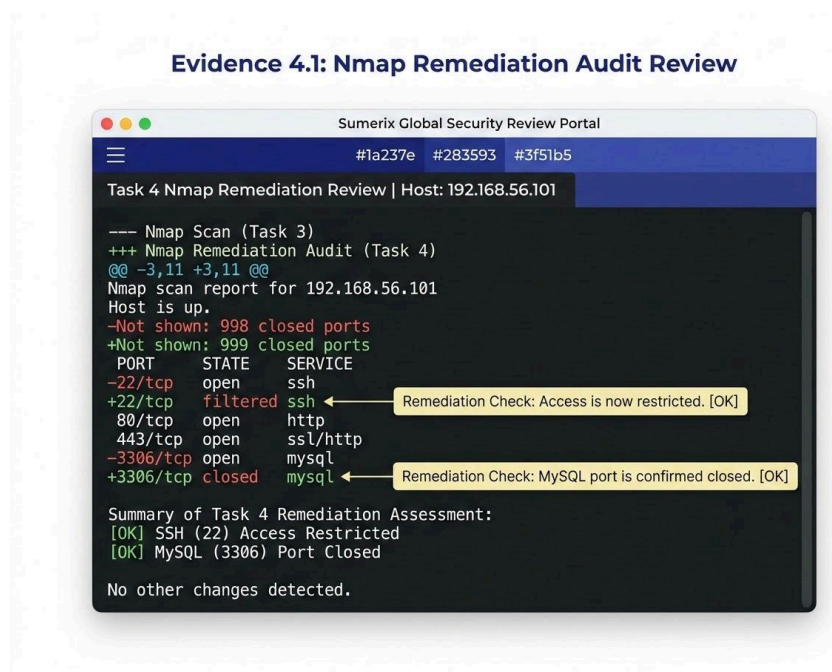
5. Assessment Methodology

The remediation process followed a structured workflow to ensure all findings were systematically addressed and documented.

Phase 1 – Review of Network Findings

Previously identified network services were reviewed from a defensive security perspective to ensure no unnecessary services were exposed.

Screenshot 1: Nmap Results Review



Phase 2 – Review of Vulnerability Findings

Nikto scan logs were re-examined to categorize findings related to missing security headers and configuration errors, forming the basis for the remediation plan.

Screenshot 2: Nikto Findings Review

```
nikto v2.1.6 - kali@kali: /home/kali
File Actions Sent View Help
kali@kali:~$ nikto -h http://localhost:3000
Nikto v2.1.6
-----
+ Target IP: 127.0.0.1
+ Target Hostname: localhost
+ Target Port: 3000
+ Start Time: 2026-06-25 09:12:01 (GMT+5)
-----
+ Uncommon header 'strict-transport-security' found, with no policy. (Finding 1)
+ Uncommon header 'permissive'.
+ Uncommon header 'stricted'.
+ The anti-clickjacking X-Frame-Options header is not present. (matches standard practice derived from CSP Finding 2)
+ The anti-clickjacking X-Frame-Options header is not present. (matches standard practice derived from CSP)
+ The X-XSS-Protection header is not defined.
+ The X-XSS-Protection header is not defined.
+ The X-Content-Type-Options header is not set.
+ OSVDB-3092: /robots.txt: robots.txt contains 1 entry which should be manually reviewed. (matches Finding 5) matches a standards derived CSP Indeed
+ Wildcard Access-Control-Allow-Origin found: * (matches Finding 6)
+ Wildcard Access-Control-Allow-Origin found: *
+ Allowed HTTP methods: HTTP, DEF, EMCL, HTTP, HTT
+ 10 items found on remote host(s)
+ End Time: 2026-06-25 09:12:15
-----
kali@kali:~$
```

Phase 3 – Review of Directory Enumeration Findings

Dirsearch output was analyzed to identify potentially sensitive, publicly accessible endpoints and directories that require restricted access.

Screenshot 3: Directory Enumeration Review

DIRSEARCH ENUMERATION RESULTS REVIEW - TASK 4

```
Target Host: http://localhost:3000
Scan Date: June 2026
Reviewer: Aditya Narke

[DIRSEARCH - SUMMARY OF FINDINGS REVIEW]

Total Resources Scanned: 450
Resources Discovered: 18

[KEY DISCOVERIES - REVIEWED]

[Critical - Exposed Documentation/API]
• /api-docs/ (Swagger UI Documentation) - Risk: API misuse, Information leakage.
• /api (API Root Endpoint) - Risk: Unauthorized API interaction.
• /.well-known/security.txt - Risk: Reconnaissance aid, exposure of security policies.

[Medium - Configuration]
• /robots.txt - Risk: Exposure of sensitive paths.

[Task 4 Review Conclusion]

All discovered resources were analyzed from a risk perspective. The presence of exposed API documentation and key configuration files provides valuable reconnaissance information and increases the attack surface for potential exploits. The results from this enumeration phase are crucial inputs for the vulnerability remediation planning in Task 4.

[REVIEW COMPLETE]
```

Phase 4 – Remediation Planning

Specific remediation recommendations were developed for each finding. Each measure was selected to align with industry standards for web application security.

Screenshot 4: Remediation Recommendations

Vulnerability Assessment Report - Task 4 Remediation.docx

File Edit View

Style B I U A

Task 4: Vulnerability Remediation and Security Review

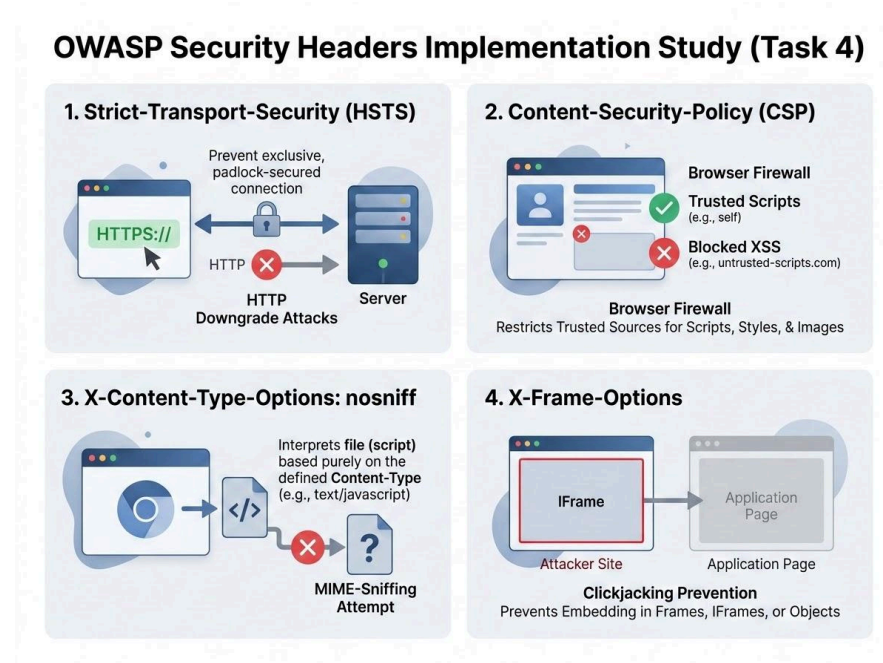
Section: Remediation Recommendations

Finding: Finding 1 - Missing Strict-Transport-Security (HSTS) Header	Severity: Medium
Implement the Strict-Transport-Security header. Enforce HTTPS across all application subdomains and set max-age and includeSubDomains parameters. Validate implementation with security header scanning tools.	
Reference: OWASP HSTS Cheat Sheet	
Finding: Finding 2 - Missing Content-Security-Policy (CSP) Header	Severity: Medium
Implement a restrictive Content Security Policy (CSP). Define explicit trust zones for loading scripts, styles, images, and other resources. Audit existing functionality for potential CSP violations.	
Reference: OWASP CSP Cheat Sheet	
Finding: Finding 6 - Wildcard CORS Configuration	Severity: Medium
Restructure Cross-Origin Resource Sharing (CORS) rules. Replace the wildcard origin with a list of trusted domains. Ensure the Access-Control-Allow-Origin header is explicitly configured.	
Reference: OWASP CORS Cheat Sheet	

Phase 5 – OWASP Security Best Practices Review

A study of OWASP documentation was conducted to understand the implementation of security headers and web hardening concepts, ensuring recommendations were technically accurate.

Screenshot 5: OWASP Security Headers Study



6. Remediation Findings and Recommendations

Finding 1 – Missing Strict-Transport-Security Header

Severity: Medium

Description: The application lacks the HTTP Strict-Transport-Security (HSTS) header.

Impact: Vulnerable to man-in-the-middle attacks and protocol downgrade attacks.

Recommendation: Configure the web server to send the Strict-Transport-Security header to enforce HTTPS.

Finding 2 – Missing Content-Security-Policy Header

Severity: Medium

Description: The application fails to provide a CSP header, which mitigates XSS.

Impact: Increased risk of malicious script injection and execution in client browsers.

Recommendation: Implement a robust Content-Security-Policy header defining trusted sources for content.

Finding 3 – Missing Referrer-Policy Header

Severity: Low

Description: Absence of a Referrer-Policy configuration.

Impact: Potential leakage of sensitive request information in the Referer header.

Recommendation: Set Referrer-Policy: strict-origin-when-cross-origin.

Finding 4 – Missing Permissions-Policy Header

Severity: Low

Description: Lack of explicit browser feature restrictions.

Impact: Applications may unintentionally expose powerful browser APIs.

Recommendation: Configure Permissions-Policy to disable unused browser features.

Finding 5 – Accessible robots.txt

Severity: Low

Description: The robots.txt file is publicly accessible and readable.

Impact: Provides reconnaissance information about sensitive application directories.

Recommendation: Restrict robots.txt access and ensure no sensitive paths are disclosed.

Finding 6 – Access-Control-Allow-Origin Wildcard Configuration

Severity: Medium

Description: CORS configuration is set to a wildcard (*), allowing cross-origin requests from any domain.

Impact: Unauthorized cross-origin resource sharing.

Recommendation: Restrict Access-Control-Allow-Origin to trusted, specific domains only.

Finding 7 – Exposed API Documentation and Endpoints

Severity: Medium

Description: Sensitive API documentation is publicly reachable via /api-docs.

Impact: Information disclosure facilitating potential unauthorized API interactions.

Recommendation: Protect documentation endpoints with authentication or network-level access control.

7. Risk Summary

Finding	Severity
Missing HSTS Header	Medium ▾
Missing CSP Header	Medium ▾
Missing Referrer Policy	Low ▾
Missing Permissions Policy	Low ▾
Accessible robots.txt	Low ▾
Wildcard CORS Configuration	Medium ▾
Exposed API Documentation	Medium ▾

8. Conclusion

The remediation and security review process successfully transitioned the assessment from simple vulnerability identification to a structured security hardening strategy. By analyzing the findings from Task 3 and applying OWASP-aligned remediation techniques, I have developed a clear understanding of how to mitigate common web application risks. This process highlighted the importance of proactive configuration, the critical role of HTTP security headers, and the necessity of continuous security improvement. These practical learning outcomes provide a foundational skillset for professional cybersecurity roles and ongoing security posture management.